CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Oski (CyberDefenders)

Análisis dinámico en entorno aislado (sandbox con Any.Run) del malware Stealc. La investigación abarca la extracción de configuración y credenciales (C2, claves RC4), análisis de comportamiento en memoria y mapeo de tácticas de evasión y robo de credenciales en el framework MITRE ATT&CK.

Sebastian David
Torres Reyes

Escenario:

El contador de la empresa recibió un correo electrónico titulado "Nuevo pedido urgente" de un cliente a última hora de la tarde. Al intentar acceder a la factura adjunta, descubrió que contenía información falsa del pedido. Posteriormente, la solución SIEM generó una alerta sobre la descarga de un archivo potencialmente malicioso. Tras una investigación inicial, se descubrió que el archivo PPT podría ser el responsable de esta descarga. ¿Podría realizar un análisis detallado de este archivo?

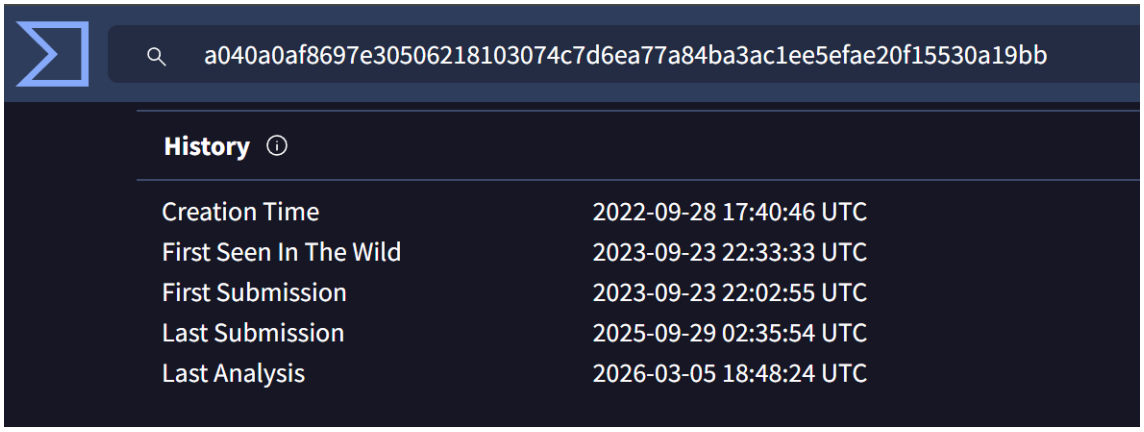
Herramientas utilizadas:

- VirusTotal
- Any.run

P1: Determinar la fecha de creación del malware puede proporcionar información sobre su origen. ¿Cuál fue la fecha de creación del malware?

R: 2022-09-28 17:40

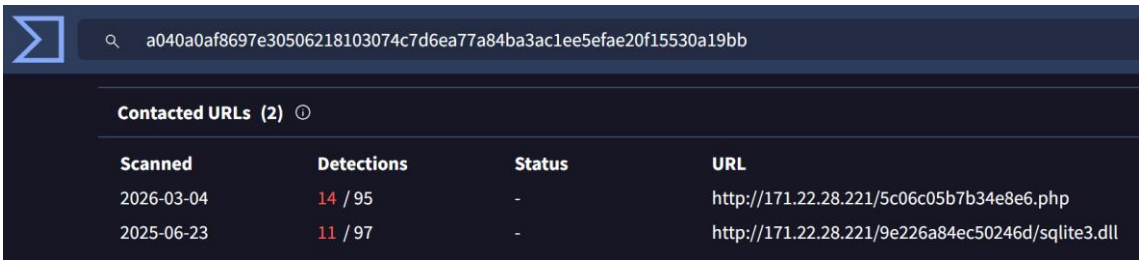
Se investigaron los detalles del malware con VirusTotal y en el historial se halló la fecha de creación.



P2: Identificar el servidor de comando y control (C2) con el que se comunica el malware puede ayudar a rastrear al atacante. ¿Con qué servidor C2 se comunica el malware del archivo PPT?

R: http://171.22.28.221/5c06c05b7b34e8e6.php

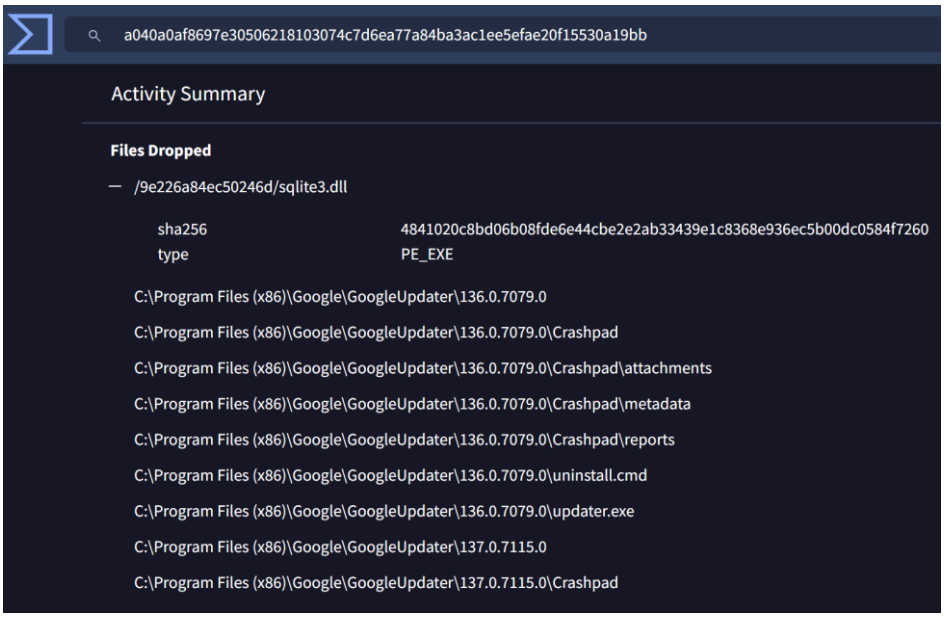
Se determinó el servidor C2 con el que se contacta el malware en la sección "Relations".



P3: Identificar las acciones iniciales del malware tras la infección puede proporcionar información sobre sus objetivos principales. ¿Cuál es la primera biblioteca que solicita el malware tras la infección?

R: sqlite3.dll

Se analizó el comportamiento del malware y se determinó que la primera biblioteca que descarga el malware fue sqlite3.dll con el objetivo de leer y exfiltrar las bases de datos que navegadores web usan para guardar las contraseñas.



P4: Al examinar el informe Any.run proporcionado, ¿qué clave RC4 utiliza el malware para descifrar su cadena codificada en base64?

R: 53295146214412479757207490 09

Tras el análisis del reporte proporcionado por Any.run se determinó que la clave RC4 fue 53295146214412479757207490 09.

Malware configuration

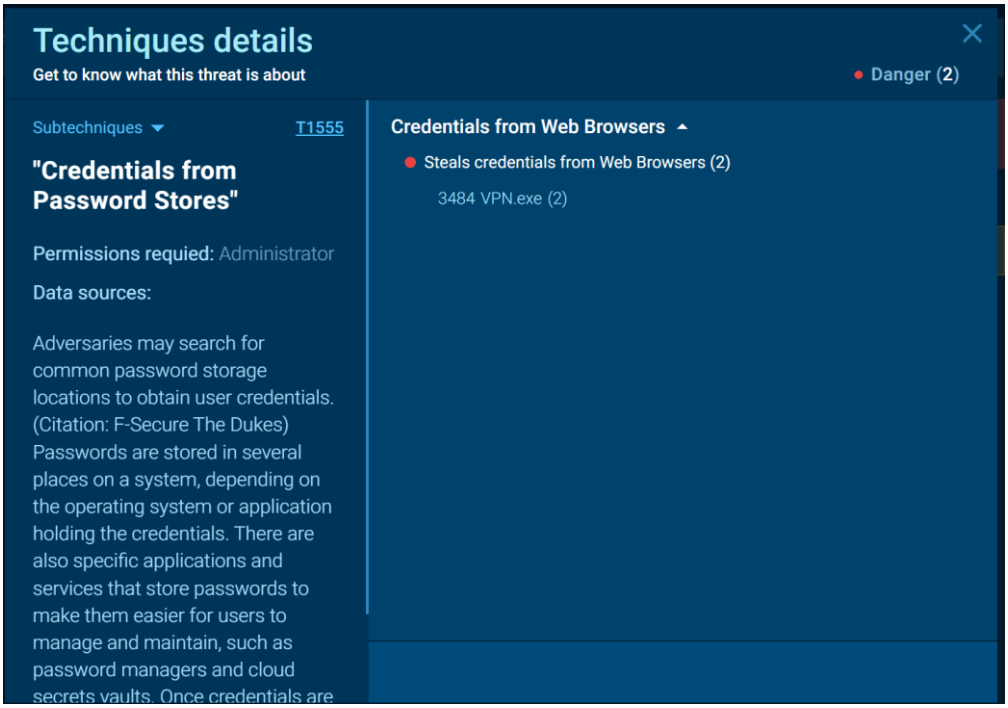
Stealc

(PID) Process	(3484) VPN.exe
C2	http://171.22.28.221/5c06c05b7b34e8e6.php
Keys	
RC4	53295146214412479757207490 09

P5: Al examinar las técnicas MITRE ATT&CK que se muestran en el informe sandbox Any.run, identifique la técnica MITRE principal (no las subtécnicas) que utiliza el malware para robar la contraseña del usuario.

R: T1555

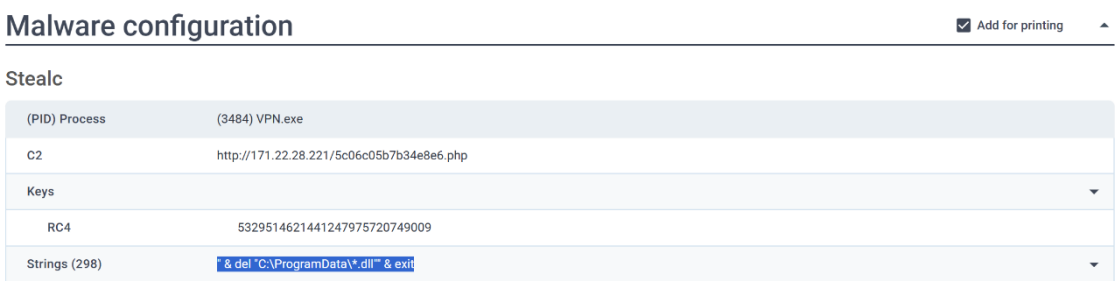
El malware usó la técnica con ID T1555 mapeada en MITRE ATT&CK. Esta técnica consiste en la búsqueda de las ubicaciones comunes que los sistemas operativos usan para guardar las contraseñas, una vez obtenidas las credenciales se pueden utilizar para realizar movimientos laterales o acceder a información restringida.



P6: Al examinar los procesos secundarios que se muestran en el informe sandbox Any.run, ¿a qué directorio apunta el malware para eliminar todos los archivos DLL?

R: C:\ProgramData

Dentro de la configuración del malware se halló que una de las cadenas legibles que se encontró en el binario del malware es una línea de comandos '" & del "C:\ProgramData*.dll"" & exit'. Este comando usa el carácter & para unir dos comandos, iniciando por borrar todos los archivos DLL del directorio C:\ProgramData y cerrando la terminal automáticamente.



P7: Comprender el comportamiento del malware tras la exfiltración de datos puede proporcionar información sobre sus técnicas de evasión. Al analizar los procesos secundarios, tras exfiltrar con éxito los datos del usuario, ¿cuántos segundos tarda el malware en autoeliminarse?

R: 5

El proceso secundario “cmd.exe” contiene una línea de comando. Inicia obligando al sistema a esperar 5 segundos para asegurar que el proceso se termine y así poder borrar el archivo correctamente. Después, se elimina forzosa y silenciosamente el ejecutable VPN.exe, es decir, el malware. Finalmente se eliminan los archivos DLL del directorio C:\ProgramData y se cierra la terminal.

Process information

PID	CMD	Path	Indicators	Parent process
2780	"C:\Windows\system32\cmd.exe" /c timeout /t 5 & del /f /q "C:\Users\admin\AppData\Local\Temp\VPN.exe" & del "C:\ProgramData*.dll"" & exit	C:\Windows\System32\cmd.exe	–	VPN.exe